



CareBlocks — Security & Data Handling Brief

Healthcare Informatics Automator Toolkit · Creative Mind Blocks · Author: Dr. Somnath V

A reusable reference for an IG (Information Governance), security, or procurement team evaluating CareBlocks — the global counterpart to COMPLIANCE.md's JCI/HIPAA-specific content. Region-specific frameworks are called out separately (UK section below) rather than assumed as the only lens.

1. WHAT CAREBLOCKS ACTUALLY DOES

CareBlocks is a lightweight Windows tool installed on an individual clinician's own workstation. It watches for two things as the clinician types in their EHR or documentation system: dangerous/ do-not-use clinical abbreviations (flagged and removed before they reach the record) and attempts to copy, cut, paste, or print patient data out of the EHR window (blocked). It also offers a single-hotkey credential-entry helper. That's the entire feature set — no note generation, no AI inference on patient content, no clinical decision-making.

2. THE ARCHITECTURAL FACT EVERYTHING FOLLOWS FROM

CareBlocks makes no outbound network calls unless a user explicitly turns on usage reporting, or explicitly chooses to send their activity log. Both are off by default. With them off — the state every installation ships in — the application makes zero outbound network calls. Every screen it shows is loaded from files bundled with the application itself — a structural property of the codebase, verifiable by network monitoring on any machine running it. There is no server operated by CareBlocks or Creative Mind Blocks that holds patient data.

This changed in v1.1 (September 2026), and is stated plainly because earlier versions of this document said “zero outbound network calls” without qualification. v1.0.0 had no reporting capability of any kind. If you evaluated CareBlocks on the earlier wording, this is what changed.

Practical consequence: most questions normally asked of a cloud health-tech vendor (where is data hosted, which sub-processors are involved, what happens on a provider-side breach) don't have a cloud answer here, because there's no cloud component. The honest complexity moves elsewhere — see Section 4.

3. DATA FLOW — WHAT CAREBLOCKS ACTUALLY TOUCHES

Data	Where it lives	Ever transmitted?
Typed text checked against the workbook	Held transiently in memory, cleared continuously	Never
Abbreviation/restriction workbook (organization-curated content)	A local .xlsx file, path chosen by the organization	Never
Saved login credentials (optional feature)	Windows Credential Manager — the OS-level secure store	Never
Activity Log (corrections/blocks made)	Local, unencrypted SQLite in the user's Windows profile	Only on a confirmed user-initiated send — see 3.1
Application settings	A local JSON file in the user's Windows profile	Never

No patient-identifiable data has a network destination. Typed text, the workbook, saved credentials and application settings are never transmitted under any configuration. This is the complete list.

3.1 The optional reporting, in full

Two channels, both off in a default installation, neither carrying note content, patient identifiers, or credentials.

Channel	How it is enabled	What it sends
---------	-------------------	---------------

Usage counts	A setting the user turns on; off by default. At most one report a day.	A random installation id, app version, Windows version, a date, and eleven totals (abbreviations expanded, warnings raised, copy/paste blocks). No text of any kind — the data structure has no field able to hold it.
Activity log	Not a setting. A button the user presses, confirming each time, having been told what it contains.	For each recorded event: the abbreviation typed and its expansion or warning message, plus timestamps.

On the installation id: a random value generated once per installation, deliberately *not* derived from machine name, Windows username, or any hardware identifier. It distinguishes one installation from another and says nothing about who is using it.

What the Activity Log is, and is not. It records matched abbreviation events, not documentation. When a specialist types *bid* and it expands, the log records *bid* and *twice a day*. It contains no note text, patient names, patient identifiers or credentials, and text a specialist defines privately as a custom shortcut is never logged at all. One edge case worth naming: a workbook-load failure records the error message, which can include a local file path that may contain the Windows username.

If your organisation's position is that none of this should leave the estate, the default configuration already satisfies that, and both controls can be verified as off on any machine.

3.2 How CareBlocks sees what is typed — the keyboard hook

CareBlocks installs a global low-level Windows keyboard hook (WH_KEYBOARD_LL). This is stated explicitly rather than left to be discovered: at the Windows API level it is the same mechanism a keylogger uses, and endpoint-protection software may flag it on that basis. What separates the two is not the mechanism but what is retained.

Held in memory. Characters accumulate in **two rolling buffers, each capped at 80 characters**. One holds the word currently being typed and is cleared on Space. The other holds recent typing since the last trigger key and is deliberately **not** cleared on Space — a prohibited term such as PRE OP contains a space and must still be caught — so it can hold up to 80 characters spanning several words. Both are cleared on Tab, Enter, Escape, Delete and the navigation keys. Both exist only in memory. Neither is ever written to disk, and no code path in the application writes either.

Event	Written to the Activity Log
Restricted term blocked	the matched workbook term, and the workbook's own warning text
Abbreviation expanded, or misspelling corrected	the matched workbook term, and its workbook replacement
Copy, cut, paste or screen capture blocked	the action only — no typed text at all
The abbreviation workbook fails to load	the error message returned by the load

The property that follows: every value the Activity Log holds *about typing* originates in the organisation-curated workbook, not in what the user typed. The log can therefore only ever contain strings that already exist in that workbook, plus timestamps. Free-text note content and patient identifiers have no path into it, because an unmatched buffer is never stored.

Scope. The hook itself is global — it has to be, to see typing in a Citrix-published EHR window — but each abbreviation and guarding feature can be configured to act only while the EHR window is in front. Configuration controls where CareBlocks *acts*, not what the hook observes, and that distinction is worth stating rather than blurring.

4. SECURITY POSTURE — STATED PLAINLY

In place today

- No outbound network calls in the default configuration (Section 2) — removes an entire category of data-in-transit and third-party-breach risk by design, not by policy. Where a user opts in, what leaves is bounded by Section 3.1 and excludes note content, patient identifiers and credentials under every configuration.
- Credentials stored via Windows Credential Manager, never in a plaintext file or the Activity Log.
- No PHI is ever aggregated, sold, or reused beyond the specialist's own in-the-moment documentation — there's no mechanism by which it could be, given Section 2.

Not yet in place — disclosed honestly

The zip build is not signed; the Store build is. CareBlocks is distributed through the Microsoft Store (live since 12 September 2026 — Section 5), where the package is signed by Microsoft and installs without the SmartScreen prompt. A zip build remains available for machines where the Store is unreachable; it is not code-signed, so Windows shows a SmartScreen prompt on its first run. A certificate would not remove that — Microsoft's guidance is that a certificate, *including EV*, no longer bypasses SmartScreen and only begins accruing reputation over hundreds of clean installs — which is why distribution, not a certificate, is the answer. **Activity Log is unencrypted SQLite** — no patient identifiers, but worth its own risk assessment for shared/unlocked-workstation scenarios. **No SOC 2 or ISO 27001** — both are built for cloud infrastructure with third-party data access, which doesn't exist here yet; a structural "not applicable yet," not a gap. **No formal penetration test** commissioned yet — a reasonable ask, noted as open. **The guard does not catch a third-party capture tool that writes straight to a file.** Copy/cut/paste are covered both at the keyboard shortcut (Ctrl+C/X/V) and at the clipboard itself, which is cleared whenever content lands there while the EHR is in front — so a right-click or menu-triggered copy *is* caught. Screen capture is intercepted at Print Screen and Win+Shift+S. What remains uncovered is a capture tool driven by its own hotkey that writes directly to a file; anything it puts on the clipboard is still cleared.

5. DEPLOYING CAREBLOCKS IN A MANAGED ENVIRONMENT

Two distribution routes exist, and they differ in exactly the way an IT team cares about. **CareBlocks is published on the Microsoft Store as of 12 September 2026**, at <https://apps.microsoft.com/detail/9P07CV1WJ28R>, after passing certification on 11 September 2026. The Store-distributed build is signed by Microsoft and is never subject to a SmartScreen download warning.

The identifiers needed to allow-list or deploy the packaged build:

Identifier	Value
Package Family Name	CreativeMindBlocks.CareBlocks_qc1n5wecx82ya
Store ID	9P07CV1WJ28R
Package SID	S-1-15-2-558288610-1457412167-1326757881-3918871750-4033680043-2120123487-2256297803
Package identity name	CreativeMindBlocks.CareBlocks
Publisher	CN=A8C21F7E-08B5-4E09-83BE-4EDBF1D1C1B0

The Package Family Name and Package SID are what an **AppLocker or WDAC packaged-app rule** keys on. The Store ID is what **Intune** takes when adding a "Microsoft Store app (new)" — and that route works even where the Store client itself is blocked for end users, which is the usual configuration on a managed clinical desktop.

The alternative route is a plain zip holding an unsigned executable, which is what the GitHub releases page serves today. It needs no installation privileges and no Store access, but the executable is unsigned, so Windows warns on first run and there is no publisher for an allow-list rule to reference. Where a managed deployment is possible, the packaged route is better on both counts.

Neither route requests elevation. CareBlocks installs no driver and no service, and runs at the same integrity level as any ordinary desktop application. The packaged build declares exactly one capability, `runFullTrust`, which Microsoft requires of any packaged desktop application running at medium integrity — a packaging requirement, not a request for additional privilege.

6. REGULATORY & STANDARDS ALIGNMENT

Global, safe regardless of country: CareBlocks' restricted-abbreviation stacks are built to support and align with the abbreviation-safety intent behind Joint Commission Standard IM.02.02.01 and JCI Standard MOI.4 — see COMPLIANCE.md for the full explanation and citations.

United Kingdom (NHS / UK Public Sector)

- **UK GDPR & the Data Protection Act 2018** — patient information is special category data. Because CareBlocks never transmits or stores data outside the specialist's own already-authorized workstation, it does not itself act as a data controller or

processor in the traditional sense — a technical description, not a formal legal determination; an organization's own DPO should confirm this for their DPIA.

- **NHS DTAC (Digital Technology Assessment Criteria)** — the standard NHS framework for assessing clinical safety, data protection, technical assurance, interoperability, and usability, updated to DTAC 2.0 in February 2026. CareBlocks' medical-device classification under DTAC 2.0's decision tree (governed by DCB0129) has not yet been formally assessed — an honest open item, not a settled position.
- **NHS DSPT (Data Security and Protection Toolkit)** — the mandatory annual self-assessment against the National Data Guardian's 10 Data Security Standards. Formal "IT Supplier" registration applies to organizations with 50+ staff and £10m+ turnover — Creative Mind Blocks sits below that threshold today. This doesn't make DSPT irrelevant: the adopting organization's own DSPT return still needs to account for CareBlocks via their normal supplier-assurance process, which this document is intended to support.

7. COMMON QUESTIONS AN IG/SECURITY TEAM IS LIKELY TO ASK

Does this monitor keystrokes? Is it a keylogger?

It uses a global low-level keyboard hook, and that is the same Windows mechanism a keylogger uses, so the question is fair and Section 3.2 answers it in full. In short: it holds two in-memory buffers, each capped at 80 characters and neither ever written to disk — one is cleared on Space, the other deliberately survives a space so that a prohibited term such as PRE OP is still caught, and both are cleared on Tab, Enter, Escape, Delete and the navigation keys; and what it records is drawn only from your own curated workbook, so arbitrary typed text has no path into storage. Endpoint-protection software may still flag the hook, which is why it is disclosed here rather than left to be found.

Where is patient data stored, and by whom?

Nowhere outside the specialist's own machine, and by no one — see Sections 2–3. There is no Creative-Mind-Blocks-operated data store of any kind.

Who has access to the data CareBlocks touches?

Exactly whoever already has access to the specialist's own Windows session — no new access path is introduced, since no new data store is introduced.

What happens if the vendor stops operating?

Nothing changes for an already-installed copy — no server, no license-check, no ongoing service dependency means it keeps working exactly as before, a direct consequence of the local-only architecture.

Is there a vulnerability disclosure or patching process?

Direct contact: cremindb@gmail.com. A direct-contact process today, not a formal published program — stated honestly rather than implied more mature than it is.

Does this require firewall exceptions or network access?

No. CareBlocks needs no network configuration to function, and no inbound access or open ports under any configuration. If a user enables usage reporting the app makes an outbound HTTPS request; if that is blocked, reporting silently does not happen and everything else works normally. **Blocking it is a supported configuration**, not a degraded one.

Is the source code available for review?

Not currently open-source — see LICENSE. A source-review arrangement under NDA is a reasonable ask for a serious procurement conversation.

What does it cost, and does that change later?

Free today, and the local single-installation version is intended to stay free — not an introductory price. A separate future paid Enterprise tier, if built, would be an entirely different, cloud-hosted product.